Technical Specifications and Platform Overview

S

Technical Specifications
and Platform Overview

Secuura Verification System (SVS)

Document Control

Version	Date	Author	Changes
1.0.0	18-02-2026	Secuura Engineering	Initial comprehensive technical specification
0.9.0	17-02-2026	Secuura Engineering	Platform hardening, Outlook Add-in, port migration
0.8.0	16-02-2026	Secuura Engineering	NFT certificates, privacy controls, analytics

Distribution

Role	Access Level
CTO / Engineering Lead	Full Document
Solution Architects	Full Document
Security Officers	Sections 7, 8, 9, 10
Product Managers	Sections 1, 2, 3, 4, 5
External Auditors	Sections 7, 8, 9, 10 (Redacted)

Table of Contents

- 1. Executive Summary
- 2. Platform Vision and Intent
- 2.1 What SVS Is
- 2.2 What SVS Is Not
- 2.3 Core Design Principles
- 3. Stakeholders and Personas
- 3.1 Issuer
- 3.2 Certifier
- 3.3 Subject
- 3.4 Rights Holder
- 3.5 Verifier
- 3.6 System Administrator
- 4. User Flows and Certification Lifecycle
- 4.1 Document Certification Flow
- 4.2 Verification Flow
- 4.3 Certification Phases
- 4.4 Rights Management
- 5. Solution Architecture
- 5.1 High-Level Architecture
- 5.2 Backend Microservices
- 5.3 Frontend Applications
- 5.4 Infrastructure and Deployment
- 5.5 Database Architecture
- 5.6 Network and Port Configuration
- 6. Component Specifications
- 6.1 API Gateway
- 6.2 Originate Service
- 6.3 Authentication Service
- 6.4 Blockchain Services
- 6.5 Verifiable Credentials
- 6.6 Governance and Staking
- 6.7 Billing and Chargeable Events

- 6.8 Analytics and Reporting
- 6.9 Privacy and Zero-Knowledge Proofs
- 7. Integration Points
- 7.1 Microsoft 365 / Graph API
- 7.2 Outlook Add-in
- 7.3 Cardano Blockchain
- 7.4 IPFS and Decentralised Storage
- 7.5 Stripe Payments
- 7.6 KYC Providers
- 7.7 JavaScript SDK
- 8. Security Architecture
- 8.1 Authentication and Authorisation
- 8.2 Encryption and Hashing
- 8.3 API Security
- 8.4 Infrastructure Security
- 9. Compliance and Standards Adherence
- 9.1 GDPR Compliance
- 9.2 NIST Cybersecurity Framework
- 9.3 W3C Standards
- 9.4 Cardano and Crypto Best Practices
- 9.5 eIDAS and Timestamping
- 10. Governance Contracts
- 10.1 DAO Governance Model
- 10.2 Proposal Lifecycle
- 10.3 Vote Delegation
- 11. Appendices
- A. Complete Port Reference
- B. Database Schema Reference
- C. API Endpoint Catalogue
- D. Environment Variable Reference
- E. Glossary

1. Executive Summary

Secuura is a blockchain-anchored document authenticity platform built on the **Secuura Verification System (SVS)**. It enables stakeholders to certify, verify, and manage the provenance of documents and credentials without Secuura itself acting as a certifier or verifier.

The platform operates on a fundamental principle: **Secuura enables and facilitates verification — it does not certify or verify itself.** Documents never leave the stakeholder's device; only cryptographic hashes are transmitted and anchored on the Cardano blockchain, providing tamper-evident, immutable proof of authenticity.

Key Capabilities

- **Client-side document hashing** using Web Crypto API (SHA-256 / BLAKE2b-256)
- **Blockchain anchoring** on Cardano (single and Merkle-batch via metadata labels 674/675)
- **W3C Verifiable Credentials** with Ed25519 signatures and StatusList2021 revocation
- **Decentralised Identity (DID)** via did:prism and did:key methods
- **Zero-knowledge proofs** for selective disclosure via Midnight protocol integration
- **DAO governance** with token-weighted voting and on-chain proposal execution
- **Microsoft 365 integration** including SharePoint, Entra ID SSO, and Outlook Add-in
- **NFT certificate minting** with multi-tier storage (on-chain, IPFS, Arweave)
- **GDPR-compliant** data subject request handling, consent management, and right to erasure
- **RFC-3161 timestamping** via eIDAS-compliant TSA integration

Technology Stack

Layer	Technologies
Frontend	React 18, TypeScript, Material UI, Vite, Office.js (Outlook Add-in)
Backend	Node.js, Express, TypeScript
Database	PostgreSQL 16 (SCRAM-SHA-256 auth), Redis 7 (caching/sessions)
Blockchain	Cardano (Blockfrost API, CIP-30/CIP-8), Midnight (ZKP)
Identity	JWT, bcrypt, TOTP MFA, CIP-30 wallet auth, Microsoft Entra ID SSO
Infrastructure	Docker, Nginx, Prometheus, Grafana
Standards	W3C VC 1.1, DID Core, GDPR, NIST CSF, eIDAS, OpenAPI 3.0

2. Platform Vision and Intent

The Secuura Verification System (SVS) addresses a fundamental trust challenge: *How can a party verify that a document or credential is authentic, without relying on a single centralised authority?*

2.1 What SVS Is

- A platform for **Verifiers to verify** that a Certifier has certified information
- An **enabler and facilitator** for Stakeholders to manage document authenticity
- A **permissionless rights management system** where Stakeholders control their own Rights
- A **provenance tracking system** that records the complete lifecycle of certifications
- A **blockchain-anchored proof system** providing tamper-evident, immutable records

2.2 What SVS Is Not

- **Not a Certifier or Verifier** — Secuura does not certify or verify documents itself
- **Not a file storage service** — original documents are never stored on Secuura servers
- **Not an encryption/data protection solution** — Secuura anchors hashes, not encrypted content
- **Not an e-signing service** — it is not a DocuSign competitor
- **Not a workflow/BPM tool** — it facilitates certification and verification, not business processes

2.3 Core Design Principles

Principle	Implementation
Client-Side Hashing	All document hashing is performed in the browser using Web Crypto API. Documents never leave the user's device.
No Document Storage	Only hashes, metadata, and URIs are stored. Original documents remain with Stakeholders.
Permissionless Rights	Stakeholders control their own Rights without central authority approval.
Immutable Provenance	All certification events form a linked chain anchored on the Cardano blockchain.
Standards-Based	W3C Verifiable Credentials, DID Core, OpenAPI 3.0, and eIDAS compliance.
Privacy by Design	GDPR-compliant from inception with zero-knowledge proof support for selective disclosure.

3. Stakeholders and Personas

The SVS defines five core stakeholder roles that interact with the platform. Each role has distinct capabilities, permissions, and user flows. A single user may hold multiple roles simultaneously.

3.1 Issuer

Definition

The Issuer is the entity that **creates the information or document**. This could be a university issuing a degree, a government agency issuing a licence, or a corporation issuing a certificate of employment.

Capabilities

- Create and register documents on the platform
- Generate client-side document hashes
- Nominate authorised signatories within their organisation
- Initiate the certification process
- View document lineage and provenance

Portal Access

Issuer Portal (`/`) — Full document management, upload, certification initiation, wallet connection, privacy controls, and settings including Outlook Add-in setup.

3.2 Certifier

Definition

The Certifier **attests to the authenticity and integrity** of information. The Certifier may be the same entity as the Issuer, or a separate trusted party. Certification creates an on-chain record.

Capabilities

- Review pending certification requests
- Digitally sign documents using CIP-30 wallet
- Anchor certification hashes on the Cardano blockchain

- Revoke certifications when necessary
- Share certifications with other stakeholders

Certification Process

The Certifier attests that a document is authentic by signing a certification record. This record includes the document hash, the Certifier's DID, a timestamp, and is anchored on the Cardano blockchain via metadata label 674 (single) or 675 (Merkle batch).

3.3 Subject

Definition

The Subject is the **person or entity that the information pertains to**. For example, the graduate named on a degree certificate, or the employee referenced in a work reference.

Capabilities

- View certifications about themselves
- Control privacy preferences for their data
- Request selective disclosure via zero-knowledge proofs
- Exercise GDPR data subject rights (access, rectification, erasure, portability)

3.4 Rights Holder

Definition

The Rights Holder has **ownership or control rights over the information**. They can share, transfer, grant access, and revoke access to certifications.

Supported Rights

Right	Description
`CERTIFY`	Attest to the authenticity of information
`ACCESS`	View the information and its certification
`SHARE`	Provide access to other stakeholders
`TRANSFER`	Move ownership or rights to another party
`VERIFY`	Check the certification status
`VIEW_PROVENANCE`	See the complete history of the document
`MODIFY_RIGHTS`	Change rights granted to others
`REVOKE_ACCESS`	Remove previously granted access

3.5 Verifier

Definition

The Verifier **checks that a Certifier has certified the information**. Verification does not verify the content of the document itself — it confirms that a trusted Certifier has attested to its authenticity.

Capabilities

- Verify certifications by document ID, file hash, or QR code
- View certification details (Certifier, date, blockchain anchor)
- Record verification events on the platform
- Initiate a new certification phase by adding a verification note

Portal Access

Verifier Portal (`/verify/`) — Public verification interface supporting verification by ID, file upload (client-side hashing), and QR code scanning.

3.6 System Administrator

Definition

The System Administrator manages platform configuration, user accounts, organisations, integrations, and system health.

Capabilities

- Manage users, organisations, and roles
- Configure document types and workflows
- Manage API keys and third-party verifiers
- Monitor system health across all services
- Configure integrations (M365, blockchain, KYC providers, Office Add-ins)
- View audit logs and generate reports
- Process GDPR data subject requests

Portal Access

Admin Dashboard (`/admin/`) — Full platform administration including Integration Hub with Office Add-in management.

4. User Flows and Certification Lifecycle

4.1 Document Certification Flow

1

Document Creation — Issuer creates or selects a document in the Issuer Portal (or via the Outlook Add-in).

2

Client-Side Hashing — The document is hashed locally in the browser using `crypto.subtle.digest('SHA-256', buffer)`. The file never leaves the device.

3

Hash Registration — Only the hash, title, and metadata are sent to the Originate Service via the API Gateway.

4

Certification Signing — An authorised Certifier signs the certification record using a CIP-30 wallet (CIP-8 message signing).

5

Blockchain Anchoring — The Anchoring Service anchors the hash on the Cardano blockchain (metadata label 674 for single, 675 for Merkle batch).

6

VC Issuance — The VC Issuer Service creates a W3C Verifiable Credential with Ed25519 proof and StatusList2021 status.

7

Timestamping — An RFC-3161 timestamp is obtained from an eIDAS-compliant TSA for legal non-repudiation.

8

Notification — Relevant stakeholders are notified of the certification event.

4.2 Verification Flow

1

Verification Request — Verifier accesses the Verifier Portal and selects a verification method (ID, file upload, or QR scan).

2

Hash Comparison — If verifying by file, the document is hashed client-side and compared against the stored hash.

3

Certification Check — The system verifies that a valid certification exists for the document hash.

4

Blockchain Verification — The blockchain anchor is verified via the Blockfrost API to confirm the transaction exists and the hash matches.

5

VC Verification — The Verifiable Credential is verified (structure, signature, status, expiration, issuer DID, blockchain anchor).

6

Result Display — The verification result is presented with Certifier details, certification date, blockchain transaction, and provenance chain.

4.3 Certification Phases

Certifications progress through phases. A Verifier can become a Certifier by adding a verification note, which creates a new linked phase.

Phase	Actor	Action	Blockchain Record
Phase 1 Start	Certifier	Certifies document	Certification hash anchored (label 674/675)
Phase 1 Active	Any Stakeholder	Shares, grants access	Access events logged
Phase 1 End	Verifier	Verifies certification	Verification event recorded

Phase 2 Start	Verifier (now Certifier)	Adds note, creates new phase	New phase hash anchored, linked to Phase 1

Phases are linked via `previousPhaseId` and all remain accessible in perpetuity on the blockchain.

4.4 Rights Management

The SVS implements a permissionless rights model. Stakeholders control their own Rights without requiring platform approval.

```
enum Right {
  CERTIFY, ACCESS, SHARE, TRANSFER,
  VERIFY, VIEW_PROVENANCE, MODIFY_RIGHTS, REVOKE_ACCESS
}

interface RightsGrant {
  stakeholderId: string;
  rights: Right[];
  grantedBy: string;
  grantedAt: string;
  expiresAt?: string;
}
```

5. Solution Architecture

5.1 High-Level Architecture

Secuura employs a microservices architecture with a unified API gateway, reverse-proxy gateway, and dedicated frontend applications for each stakeholder role.

Architecture Layers

Layer	Components	Technology
Presentation	Issuer Portal, Verifier Portal, Admin Dashboard, Status Page, Website, Outlook Add-in	React, TypeScript, MUI, Office.js
Gateway	Nginx Reverse Proxy, API Gateway	Nginx 1.25, Express
Application	21 microservices (originate, auth, anchoring, prism, vc-issuer, etc.)	Node.js, Express, TypeScript
Data	PostgreSQL, Redis, PGBouncer	PostgreSQL 16, Redis 7
Blockchain	Cardano node, Blockfrost API, Midnight	Cardano Preprod/Mainnet
External	Microsoft Graph API, Stripe, IPFS, KYC providers, TSA	REST APIs

5.2 Backend Microservices

All services follow a consistent pattern: Express server, PostgreSQL connection with in-memory fallback, Redis for caching/sessions, health endpoint, and structured Winston logging.

Service	Internal Port	External Port	Purpose	Status
API Gateway	8080	—	Request routing, auth, rate limiting, Swagger docs	Active
Originate	4000	6000	Document certification, verification, GDPR, provenance	Active
Auth	4003	6003	Authentication, JWT, MFA, wallet auth, sessions	Active
PRISM	4001	6001	DID management, credential issuance	Active
Anchoring	4005	6005	Blockchain anchoring (single and Merkle batch)	Active
Wallet				

Connector	4002	6002	CIP-30 wallet integration	Active
Timestamping	4004	6004	RFC-3161 timestamping	Active
Security	4008	6008	Audit logs, API key management, security events	Active
Analytics	4010	6010	Platform metrics, reports, real-time analytics	Active
M365 Integration	4013	6013	SharePoint, Entra ID, Outlook Add-in support	Active
VC Issuer	4014	6014	W3C Verifiable Credential issuance, StatusList2021	Active
Staking	4015	6015	Token staking, tier management, rewards	Active
Referral	4016	6016	Referral programme, milestones, leaderboard	Active
Governance	4017	6017	DAO governance, proposals, voting	Active
NFT Certificate	4018	6018	NFT minting, multi-tier storage, IPFS	Active
Billing	4019	6019	Stripe payments, certification bundles, chargeable events	Active
Transfer	4020	6020	Ownership transfers, delegations	Active
KYC	4011	6011	Identity verification (Onfido, Jumio)	Active
Midnight	4012	6012	Zero-knowledge proofs, selective disclosure	Active
Guardian	4006	6006	Guardian recovery (planned)	Phase 2
Queue	4007	6007	Message queue (planned)	Phase 2

5.3 Frontend Applications

	Dev	Gateway		

Application	Port	Route	Technology	Purpose
Issuer Portal	6100	`/`	React, MUI, Vite	Document management, certification, wallet, settings
Verifier Portal	6101	`/verify/`	React, Vite	Public verification by ID, file, QR
Admin Dashboard	6102	`/admin/`	React, MUI, Recharts, Vite	Platform administration, integration hub
Website	6103	`/website/`	React, Vite	Marketing, tokenomics, whitepaper
Status Page	—	`/status/`	React	Public system health status
Outlook Add-in	6104	—	React, Office.js, Fluent UI	Verify/certify from Outlook email

5.4 Infrastructure and Deployment

Container Orchestration

All services are containerised with Docker and orchestrated via Docker Compose. Each service has a dedicated Dockerfile with multi-stage builds for production optimisation.

Reverse Proxy (Nginx Gateway)

A single Nginx instance on port **6882** serves as the unified entry point, routing requests to all frontend applications and backend services. It provides security headers, WebSocket support (HMR), and production-ready TLS configuration.

Database

PostgreSQL 16 with SCRAM-SHA-256 authentication, initialised via SQL migration scripts in `docker/init/`. PGBouncer provides connection pooling in production. Redis 7 provides session storage, rate limiting, and

caching with AOF persistence and 256MB memory limit.

Monitoring

Prometheus metrics collection and Grafana dashboards are available via the `monitoring` Docker profile on ports 6301 and 6300 respectively.

5.5 Database Architecture

The PostgreSQL database contains 50+ tables organised across functional domains:

Domain	Key Tables	Purpose
Users & Auth	`users`, `user_sessions`, `refresh_tokens`, `wallet_registrations`	Identity, authentication, sessions
Organisations	`organizations`, `organization_members`	Multi-tenant organisation model
Documents	`documents`, `document_versions`, `document_signatures`, `document_access`	Document records, versioning, access control
Blockchain	`blockchain_anchors`, `merkle_batches`	Cardano transaction records
Provenance	`certification_events`	Linked chain of all certification lifecycle events
Identity	`did_documents`, `verifiable_credentials`	DIDs and VCs
GDPR	`consent_records`, `data_subject_requests`, `data_deletion_log`, `data_retention_policies`	Compliance records
Governance	`svc_proposals`, `svc_governance_participants`, `svc_vote_delegations`	DAO voting and proposals
Billing	`billing_charge_events`, `pricing_config`	Revenue tracking, pricing

Privacy	`svc_zk_proofs`, `svc_commitments`, `svc_disclosure_audit`	Zero-knowledge proofs
Admin	`document_type_configs`, `workflow_configs`, `admin_integrations`	Platform configuration

5.6 Network and Port Configuration

All services communicate via an internal Docker bridge network (`secuura-network`). Only two ports are exposed externally:

Port 6882 — Nginx Gateway (unified entry point for all portals and APIs)

Port 6881 — Marketing Website (direct access)

Internal service ports use the 4000–4020 range. Host-mapped debug ports use the 6000–6020 range. Frontend dev servers use the 6100–6104 range. Infrastructure services use the 6300–6432 range.

6. Component Specifications

6.1 API Gateway

The API Gateway serves as the central entry point for all API requests, providing authentication, rate limiting, input sanitisation, and request routing to backend services.

Feature	Implementation
Rate Limiting (Auth)	5 login attempts per 15 minutes (production), 10 (development)
Rate Limiting (API)	60 requests/minute (production), 100 (development)
Rate Limiting (Verification)	100 requests/minute (production), 200 (development)
Brute Force Protection	5 free retries, exponential backoff (500ms–30s), 5-minute lockout

Input Sanitisation	HTML entity encoding for XSS prevention on all request bodies
Suspicious Request Detection	Pattern matching for path traversal, XSS, SQL injection, command injection
JWT Validation	HS256 with configurable secret; production fails if default secret is used
CSRF Protection	Token-based CSRF middleware with configurable secret
Security Headers	Helmet.js with HSTS, X-Frame-Options (DENY), CSP, Permissions-Policy
API Documentation	Swagger UI at `/api/docs`, OpenAPI 3.0 spec at `/api/docs/openapi.json`

6.2 Originate Service

The core document management service handling certification, verification, GDPR compliance, provenance tracking, and administrative configuration.

Key Endpoint Groups

- `/api/certifications/*` — Issue, revoke, verify, share, recertify, lineage, evidence bundles
- `/api/documents/*` — Create, sign, anchor, QR generation
- `/api/verification/*` — Hash verification, integrity checks
- `/api/gdpr/*` — Consent management, DSR handling, data export, erasure, retention
- `/api/signatories/*` — Authorised signatory management
- `/api/third-party-verifiers/*` — Third-party verifier registration and management
- `/api/admin/*` — Pricing configuration, document types, workflows
- `/api/system-errors/*` — Error tracking and ingestion

6.3 Authentication Service

Authentication Methods

Method	Mechanism	Use Case
Email / Password	bcrypt hashing, JWT access + refresh tokens	Standard user authentication
Wallet (CIP-30)	CIP-8 challenge/response, wallet signature verification	Cardano wallet holders
Microsoft Entra ID	OAuth 2.0 via MSAL, SSO token exchange	Enterprise users with M365
MFA (TOTP)	Time-based one-time passwords with backup codes	Enhanced account security

Token Management

- **Access Tokens:** Short-lived JWT stored in-memory (not localStorage)
- **Refresh Tokens:** httpOnly cookies with automatic rotation
- **Sessions:** Redis-backed with configurable expiry and revocation support

6.4 Blockchain Services

Anchoring Service

Anchors document hashes on the Cardano blockchain using two strategies:

- **Single Anchor (Label 674):** One document hash per transaction for high-value documents
- **Merkle Batch (Label 675):** Multiple document hashes combined into a Merkle tree root for cost efficiency

Supports mock mode for development and Blockfrost API for preprod/mainnet.

PRISM Service

Manages Decentralised Identifiers (DIDs) supporting `did:prism` and `did:key` methods. Provides DID creation, resolution, update, and deactivation, as well as credential issuance and verification.

Wallet Connector

Implements CIP-30 wallet integration supporting Nami, Eternl, Lace, and Flint wallets. Handles wallet registration, signature verification, and multi-network support (devnet, preprod, mainnet).

6.5 Verifiable Credentials

Standards Compliance

Fully compliant with the **W3C Verifiable Credentials Data Model 1.1** specification.

Feature	Implementation
Proof Type	Ed25519Signature2020
Status Mechanism	StatusList2021 (bitstring-based revocation)
DID Methods	did:prism, did:key
Credential Subject	Document hash, type, issuer, certification metadata
Blockchain Anchor	Cardano transaction hash, block height, network
Provenance	Linked provenance entries within credential

Verification Checks

Seven verification checks are performed: structure validity, context validation, Ed25519 signature verification, status list check (revocation), expiration check, issuer DID resolution, and blockchain anchor verification.

6.6 Governance and Staking

DAO Governance Model

Token-weighted voting with tier multipliers. Participants register with their staked amount and receive vote power based on their tier.

Tier	Minimum Stake	Vote Multiplier
Basic	< 1,000 SECURA	1.0x
Staker	≥ 1,000 SECURA	1.0x
Validator	≥ 10,000 SECURA	1.5x
Partner	≥ 100,000 SECURA	2.0x

Default governance: 50% approval threshold, 30% quorum, 7-day voting period, 24-hour timelock.

6.7 Billing and Chargeable Events

Pricing Model

Event Type	ADA Price	USD Price	Typical Payer
Certification Signing	5 ADA	$2.00	Issuer / Certifier
Blockchain Anchor	2 ADA	$0.80	Issuer / Certifier
Verification	0.5 ADA	$0.20	Verifier
Verification Certificate	3 ADA	$1.20	Verifier
Rights Transfer	3 ADA	$1.20	Rights Holder
Share	Free	Free	—
Premium Timestamp	10 ADA	$4.00	Requesting Party
Evidence Export	1 ADA	$0.40	Requesting Party
API Access	0.1 ADA	$0.04	API Consumer

Volume Discounts

100+ events: 5% • 500+: 10% • 1,000+: 15% • 5,000+: 20% • 10,000+: 25%

6.8 Analytics and Reporting

The Analytics Service provides platform-wide metrics, real-time dashboards, and exportable reports.

- **Overview metrics:** Total certifications, verifications, users, revenue
- **Certification metrics:** By type, by organisation, by time period
- **Governance metrics:** Active proposals, participation rates, vote power distribution
- **Revenue metrics:** By event type, by organisation, volume discounts applied
- **Real-time metrics:** Active users, pending operations, service health
- **Report generation:** Scheduled and on-demand reports with export to CSV/JSON

6.9 Privacy and Zero-Knowledge Proofs

The Midnight protocol integration enables selective disclosure of credential attributes without revealing the full credential.

Supported ZKP Circuits

Circuit	Purpose	Example
Ownership Proof	Prove ownership of a credential	“I hold a valid degree”
Age Verification	Prove age threshold without revealing date of birth	“I am over 18”
Credential Proof	Prove specific credential attributes	“My degree is in Computer Science”
Membership		“I am a member of

Proof	Prove membership in a group	Organisation X"
Range Proof	Prove a value falls within a range	"My salary is between $50K and $100K"

7. Integration Points

7.1 Microsoft 365 / Graph API

Overview

The M365 Integration Service connects Secuura to the Microsoft ecosystem via the Microsoft Graph API, enabling document synchronisation from SharePoint, identity federation via Entra ID, and Outlook integration.

Integration	Protocol	Endpoints
Microsoft Entra ID (Azure AD)	OAuth 2.0 / OIDC via MSAL	`/api/connections/*`
SharePoint Document Libraries	Microsoft Graph API v1.0	`/api/sites/*`, `/api/documents/*`
OneDrive File Access	Microsoft Graph API v1.0	`/api/documents/*`
Outlook Add-in SSO	OAuth 2.0 On-Behalf-Of	`/api/outlook/*`

Authentication Flow

The service uses MSAL (Microsoft Authentication Library) for OAuth 2.0 authentication. Tokens are managed with automatic refresh, and the `expiresIn` value is computed from the `expiresAt` timestamp returned by the token manager.

Environment Configuration

```
ENTRA_TENANT_ID=xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxx
ENTRA_CLIENT_ID=xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxx
ENTRA_CLIENT_SECRET=your-client-secret
ENTRA_REDIRECT_URI=https://app.secuura.com/auth/callback
```

7.2 Outlook Add-in

Architecture

A Microsoft Office Add-in built with React, Office.js, and Fluent UI v9 that integrates directly into the Outlook ribbon. It enables stakeholders to verify and certify email attachments without leaving Outlook.

Capabilities

- **Verify Attachments:** Hash email attachments client-side and check against the Secuura blockchain
- **Certify Documents:** Register uncertified attachments for certification
- **Quick Verify:** One-click ribbon button for instant batch verification
- **SSO:** Microsoft Entra ID single sign-on via On-Behalf-Of flow

Deployment

Method	Scope	Description
Centralised Deployment	Organisation-wide	Deployed via M365 Admin Centre for all users
Sideload	Individual	Manual install via Outlook → Get Add-ins → Custom Add-ins
AppSource	Public	Published to Microsoft AppSource marketplace

Manifest URL: `https://[host]/outlook-addin/manifest.xml`

Dev server: `https://localhost:6104` (HTTPS required for Office Add-ins)

7.3 Cardano Blockchain

Integration Points

Service	Integration	Protocol
Anchoring	Document hash anchoring	Blockfrost API, metadata labels 674/675
PRISM	DID management	Cardano PRISM, did:prism method
Wallet Connector	Wallet authentication	CIP-30 (dApp connector), CIP-8 (message signing)
NFT Certificate	Certificate minting	CIP-25 (NFT standard), CIP-30
Staking	Token staking	Cardano staking delegation
Governance	On-chain voting	Transaction metadata, datum hashing

Network Support

- **Devnet:** Local Yaci DevKit for development (ports 6091–6093)
- **Mock:** Mock Cardano responses for testing (port 6090)
- **Preprod:** Cardano pre-production testnet via Blockfrost
- **Mainnet:** Cardano mainnet via Blockfrost (production)

7.4 IPFS and Decentralised Storage

The NFT Certificate Service supports multiple storage tiers for certificate metadata and assets:

Tier	Storage	Persistence	Use Case
On-Chain	Cardano transaction metadata	Permanent (blockchain)	Small metadata, high-value certificates
	Pinata / Infura /	Permanent	Standard certificates,

IPFS	Web3.Storage	(pinned)	documents
Arweave	Arweave permaweb	Permanent (incentivised)	Long-term archival
Centralised	Secuura CDN	Managed	Low-cost, convenience

7.5 Stripe Payments

The Billing Service integrates with Stripe for fiat payment processing. Supports certification bundle purchases with credit tracking.

- **Checkout:** Stripe Checkout sessions for secure payment
- **Webhooks:** `/webhooks/stripe` handles payment confirmations, refunds, and disputes
- **Bundles:** Pre-purchased certification credit bundles (credits never expire)
- **Modes:** Test mode (development) and live mode (production)

7.6 KYC Providers

Identity verification via pluggable KYC providers:

- **Mock:** Development testing with configurable results
- **Onfido:** Document verification and facial biometrics
- **Jumio:** AI-powered identity verification
- **Microsoft Entra ID:** Enterprise identity verification via `/api/kyc/microsoft/*`

7.7 JavaScript SDK

The `@secuura/sdk` package provides a typed JavaScript/TypeScript client for integrating with the Secuura API.

Modules

- `CertificationsModule` — Create, verify, revoke certifications
- `GovernanceModule` — Proposals, voting, delegation
- `PrivacyModule` — ZKP generation, selective disclosure
- `TransfersModule` — Ownership transfers, delegations
- `KycModule` — Identity verification workflows
- `WebhooksModule` — Webhook subscription and handling

Build output: CommonJS + ESM + TypeScript declarations via tsup.

8. Security Architecture

8.1 Authentication and Authorisation

Control	Implementation
Password Hashing	bcrypt with automatic salt generation
JWT Tokens	HS256, short-lived access tokens, httpOnly refresh cookies
Token Rotation	Automatic refresh with sliding window expiry
MFA	TOTP (RFC 6238) with encrypted backup codes
Wallet Auth	CIP-8 challenge/response with nonce-based replay prevention
Session Management	Redis-backed with configurable TTL and forced revocation
RBAC	Role-based access control (SYSTEM_ADMIN, ORG_ADMIN, USER)
Production Guard	JWT_SECRET validation fails if default value is used in production

8.2 Encryption and Hashing

Purpose	Algorithm	Location
Document Hashing	SHA-256 (Web Crypto API) or BLAKE2b-256	Client-side (browser)

Password Hashing	bcrypt (adaptive cost factor)	Auth Service
API Key Hashing	SHA-256	Security Service
Token Hashing	SHA-256 (session tokens, refresh tokens)	Auth Service
VC Signing	Ed25519 (Ed25519Signature2020)	VC Issuer / Shared Package
TLS	TLSv1.2 / TLSv1.3 (ECDHE-ECDSA-AES128/256-GCM-SHA256/384)	Nginx Gateway
Database Auth	SCRAM-SHA-256	PostgreSQL
Redis Auth	Password-based with requirepass	Redis

8.3 API Security

Security Headers

Header	Value
X-Frame-Options	DENY (API Gateway) / SAMEORIGIN (Nginx)
X-Content-Type-Options	nosniff
X-XSS-Protection	1; mode=block
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	geolocation=(), microphone=(), camera=()
Strict-Transport-Security	max-age=63072000; includeSubDomains; preload (production)
Content-Security-Policy	default-src 'self'; script-src 'self' 'unsafe-inline'; connect-src 'self' https://*.blockfrost.io

Input Protection

- **XSS:** HTML entity encoding on all request body values
- **SQL Injection:** Parameterised queries, suspicious pattern detection
- **Path Traversal:** Pattern matching on URLs (`../` detection)
- **Command Injection:** `exec(` pattern detection in request bodies
- **CORS:** Explicit origin whitelist with credentials support

8.4 Infrastructure Security

Control	Implementation
Network Isolation	Docker bridge network; only ports 6881/6882 exposed externally
Container Security	Non-root users, read-only filesystems where possible, resource limits
Secret Management	Environment variables, never committed to version control
Database Security	SCRAM-SHA-256 auth, dedicated user, init script-based schema
Redis Security	Password-protected, max memory limit (256MB), LRU eviction
Health Checks	All services implement `/health` endpoint with dependency status
Resource Limits	CPU and memory limits per container (e.g., API Gateway: 1 CPU, 512MB)
Logging	Structured JSON logging via Winston, no PII in logs

9. Compliance and Standards Adherence

9.1 GDPR Compliance

Secuura implements comprehensive GDPR compliance through the Originate Service's `/api/gdpr/*` endpoints.

GDPR Article	Requirement	Implementation
Art. 6	Lawful Basis for Processing	Consent records with purpose, version, source tracking. Consent can be withdrawn at any time.
Art. 7	Conditions for Consent	Explicit consent recording with IP address and user agent capture. Withdrawal endpoint available.
Art. 15	Right of Access	DSR type “access”. Full user data export via `/api/gdpr/export/:userId`.
Art. 16	Right to Rectification	DSR type “rectification” with admin review workflow.
Art. 17	Right to Erasure	Cascading deletion across 9 data categories via `/api/gdpr/erasure/:userId`. Includes hard deletion, anonymisation, and audit trail.
Art. 18	Right to Restriction	DSR type “restriction” with status tracking.
Art. 20	Right to Portability	JSON data export with download endpoint. Content-Disposition: attachment.
Art. 21	Right to Object	DSR type “objection” with 30-day processing deadline.
Art. 30	Records of Processing	Audit log table with user_id, action, resource_type, IP address, timestamp.
Art. 32	Security of Processing	Encryption at rest (PostgreSQL), TLS in transit, access controls, pseudonymisation.
Art. 33/34	Breach Notification	Security event tracking via Security Service with severity classification.

Data Retention

Configurable retention policies per data type with automatic enforcement. Deletion methods include hard delete, soft delete, and anonymisation. All deletions are logged in `data_deletion_log` with records affected count.

9.2 NIST Cybersecurity Framework

Function	Category	Secuura Implementation
Identify	Asset Management	Service catalogue with health monitoring; database schema with defined data classifications
Identify	Risk Assessment	Suspicious request detection; brute-force monitoring; security event classification
Protect	Access Control	RBAC, JWT auth, MFA, wallet auth, session management
Protect	Data Security	Client-side hashing, TLS 1.2/1.3, bcrypt, Ed25519, SCRAM-SHA-256
Protect	Maintenance	Docker containerisation, version-controlled deployments, healthchecks
Detect	Anomaly Detection	Suspicious pattern matching, rate limiting, brute-force detection
Detect	Monitoring	Prometheus metrics, Grafana dashboards, structured logging
Respond	Incident Response	Security event tracking, audit logs, IP-based blocking
Recover	Recovery Planning	PostgreSQL persistent volumes, Redis AOF, Docker restart policies

9.3 W3C Standards

Standard	Version	Implementation
Verifiable Credentials Data Model	1.1	Full implementation via VC Issuer Service and shared VC builder/verifier
DID Core	1.0	did:prism and did:key methods via PRISM Service
StatusList2021	Draft	Bitstring-based credential revocation status lists
JSON-LD	1.1	VC context processing with standard credential contexts

9.4 Cardano and Crypto Best Practices

CIP	Title	Usage
CIP-8	Message Signing	Wallet authentication challenge/response
CIP-25	NFT Metadata Standard	NFT certificate metadata structure
CIP-30	Cardano dApp Connector	Wallet connection (Nami, Eternl, Lace, Flint)
Label 674	Single Document Metadata	Individual document hash anchoring
Label 675	Batch Metadata	Merkle root anchoring for batch documents

Blockchain Best Practices

- Merkle tree batching reduces on-chain costs while maintaining individual verifiability
- Transaction confirmation polling with retry logic for reliable anchoring
- Network-agnostic configuration supporting devnet, preprod, and mainnet
- Mock mode for development eliminates blockchain dependency during testing

9.5 eIDAS and Timestamping

The Timestamping Service implements RFC-3161 timestamping via eIDAS-compliant Timestamp Authorities.

- **TSA Provider:** D-Trust eIDAS TSA (configurable)
- **Protocol:** RFC 3161 Timestamp Protocol
- **Storage:** Timestamp tokens stored alongside document records
- **Verification:** Timestamp tokens can be independently verified against the TSA
- **Legal Standing:** eIDAS-qualified timestamps provide legal non-repudiation across EU member states

10. Governance Contracts

10.1 DAO Governance Model

Secuura implements decentralised governance through token-weighted voting, allowing SECURA token holders to participate in platform decisions.

Proposal Categories

Category	Description	Typical Use
`parameter_change`	Protocol parameter adjustments	Rate limit changes, pricing updates
`fee_adjustment`	Fee structure changes	Certification pricing, discount thresholds
`treasury_spend`	Treasury fund allocation	Development funding, marketing
`upgrade`	Protocol upgrades	New service deployments, breaking changes
`emergency`	Emergency actions	Security patches, incident response
`governance_change`	Governance rule changes	Voting period adjustments, quorum changes
`whitelist`	Whitelist management	Approved verifier/certifier lists
`general`	General proposals	Community initiatives

10.2 Proposal Lifecycle

1

Draft — Proposer creates proposal (requires minimum 1,000 SECURA staked)

2

Active — Proposal submitted, 7-day voting period begins

3

Voting — Participants cast votes (for/against/abstain) weighted by staked amount and tier multiplier

4

Queued — If passed (50% approval, 30% quorum), enters 24-hour timelock

5

Executed — After timelock, proposal actions are executed

Proposals that fail to meet the approval threshold or quorum are automatically cancelled after the voting period ends (checked every 60 seconds by the governance scheduler).

10.3 Vote Delegation

Token holders can delegate their vote power to another participant, enabling representative governance.

- Delegation can be **universal** (all proposals) or **category-specific**
- Delegated power equals the delegator's `staked_amount × tier_multiplier`
- Delegations can be revoked at any time
- Delegations can have an expiry date
- Supports DRep (Delegated Representative) and Constitutional Committee roles

11. Appendices

Appendix A — Complete Port Reference

Service	Internal Port	External (Host) Port	Gateway Route
Nginx Gateway	80	6882	Unified entry point
Website (direct)	80	6881	`/website/`
API Gateway	8080	—	`/api/`
Originate	4000	6000	`/originate/`
PRISM	4001	6001	—
Wallet Connector	4002	6002	—
Auth	4003	6003	—
Timestamping	4004	6004	—
Anchoring	4005	6005	—
Guardian	4006	6006	—
Queue	4007	6007	—
Security	4008	6008	—
Analytics	4010	6010	`/analytics/`
KYC	4011	6011	—
Midnight	4012	6012	—
M365 Integration	4013	6013	—
VC Issuer	4014	6014	—
Staking	4015	6015	—
Referral	4016	6016	—
Governance	4017	6017	—
NFT Certificate	4018	6018	—
Billing	4019	6019	—
Transfer	4020	6020	—
PostgreSQL	5432	6432	—
Redis	6379	6379	—

PGBouncer	6432	6433	—
Cardano Mock	80	6090	—
Cardano Devnet CLI	3001	6091	—
Cardano Submit API	8090	6092	—
Cardano Node	10000	6093	—
Grafana	3000	6300	—
Prometheus	9090	6301	—
Issuer Portal (dev)	—	6100	`/`
Verifier Portal (dev)	—	6101	`/verify/`
Admin Dashboard (dev)	—	6102	`/admin/`
Website (dev)	—	6103	`/website/`
Outlook Add-in (dev)	—	6104	—

Appendix B — Database Schema Reference

Core Tables

Table	Key Columns	Purpose
`users`	id, email, password_hash, role, status, mfa_enabled	User accounts
`organizations`	id, name, slug, type, status, did	Organisation records
`documents`	id, content_hash, title, document_type, status, issuer_organization_id	Document records (hash only)
`certification_events`	id, document_id, event_type, event_hash, previous_event_id, actor_user_id	Provenance chain
`blockchain_anchors`	id, document_id, anchor_type, content_hash, transaction_hash, block_number	Blockchain records
`verifiable_credentials`	credential_id, issuer_did, holder_did,	W3C VCs

	credential_subject, proof, status	
consent_records	user_id, purpose, version, given_at, withdrawn_at	GDPR consent
data_subject_requests	type, user_id, status, deadline, completed_at	GDPR DSRs
audit_logs	user_id, action, resource_type, ip_address, success	Audit trail

Appendix C — API Endpoint Catalogue

Service	Base Path	Key Endpoints
Auth	/api/auth	login, register, refresh, logout, verify-email, reset-password, wallet/*, mfa/*
Certifications	/api/certifications	create, verify, revoke, share, recertify, lineage, evidence-bundle
Documents	/api/documents	create, sign, anchor, qr, list, detail
Verification	/api/verification	verify-hash, verify-integrity, check-status
GDPR	/api/gdpr	consent, consent/withdraw, dsr, export, erasure, retention
Anchoring	/api/anchors	create, batch, verify, queue
DIDs	/api/did	create, resolve, update, deactivate
Credentials	/api/credentials	issue, verify, revoke, list
Governance	/api/governance	proposals/*, vote, delegate, participants/*, config, stats
Staking	/api/stake	stake, unstake, rewards/*, tiers/*
NFT	/api/nft	record, estimate, certificates/*, tiers, privacy-options
M365	/api/connections	connect, callback, refresh, sites/*, documents/*, outlook/*
Analytics	/api/analytics	overview, certifications, verifications, governance, revenue, realtime
Billing	/billing	bundles/*, checkout/*, customers/*

Admin	`/api/admin`	document-types, workflows, integrations, settings, users, health

Appendix D — Environment Variable Reference

Variable	Service	Description
`JWT_SECRET`	All	JWT signing secret (must be changed in production)
`DATABASE_URL`	All	PostgreSQL connection string
`REDIS_URL`	All	Redis connection string
`CORS_ORIGINS`	Gateway	Comma-separated allowed origins
`BLOCKFROST_API_KEY`	Anchoring, NFT	Blockfrost API project ID
`CARDANO_NETWORK`	Blockchain services	devnet, preprod, or mainnet
`ENTRA_TENANT_ID`	M365	Microsoft Entra ID tenant
`ENTRA_CLIENT_ID`	M365	Azure app registration client ID
`ENTRA_CLIENT_SECRET`	M365	Azure app registration client secret
`STRIPE_SECRET_KEY`	Billing	Stripe API secret key
`STRIPE_WEBHOOK_SECRET`	Billing	Stripe webhook signing secret
`IPFS_PROVIDER`	NFT	IPFS provider (pinata, infura, web3storage, mock)
`RATE_LIMIT_MAX_REQUESTS`	Gateway	Maximum API requests per minute

Appendix E — Glossary

Term	Definition
SVS	Secuura Verification System — the overarching platform model
Certifier	Entity that attests to the authenticity and integrity of information
Verifier	Entity that checks a Certifier has certified information
Rights Holder	Entity with ownership or control rights over information

DID	Decentralised Identifier — a W3C standard for self-sovereign identity
VC	Verifiable Credential — a W3C standard for tamper-evident credentials
CIP	Cardano Improvement Proposal — community standards for Cardano
ZKP	Zero-Knowledge Proof — a cryptographic method to prove a statement without revealing the underlying data
DAO	Decentralised Autonomous Organisation — governance via token-weighted voting
eIDAS	EU regulation for electronic identification, authentication, and trust services
MSAL	Microsoft Authentication Library — OAuth 2.0 client for Microsoft identity
Merkle Tree	Hash tree structure used for efficient batch verification of multiple documents
TSA	Timestamp Authority — provides RFC-3161 trusted timestamps

End of Document

Secuura Verification System — Technical Specifications and Platform Overview

Version 1.0.0 • 18 February 2026

© 2026 Secuura. All rights reserved.